Atributos de calidad en RECAUDO-T

Parte 2: Práctica - Variante V5: Ola de fraudes

Atributo prioritario: Seguridad **Atributo secundario:** Disponibilidad

Base: Parte 1 - Análisis RECAUDO-T ampliado, variante V5.

Escenarios seleccionados en Parte 1: S2, P1 y D1.

Nota de cumplimiento: la Parte 2 prohíbe usar como tácticas de práctica Ping/Echo, Redundancia Activa, Introducir Concurrencia y Caché. Por eso se conserva S2 y se ajustan P1 y D1 de forma mínima: P1 usa priorización de validaciones y D1 usa standby pasivo con lease TTL. El intercambio HTTP, los procesos y las mediciones sí son reales dentro de la simulación.

Documento de trabajo generado a partir de los criterios de la Parte 2. Las cifras de desempeño indicadas como muestra son corridas locales de 2 s; para el entregable final debe ejecutarse el comando de 600 s indicado en el README.

1. Táctica S2 - Autorizar actores + bloqueo por umbral

Escenario de la Parte 1: 500 consultas de saldo de tarjetas ajenas en 1 minuto. La respuesta esperada es rechazar toda consulta ajena con HTTP 403, bloquear después de la consulta ajena número 10 y no exponer saldos ajenos.

Cómo funciona: cada token está asociado a un usuario. Antes de devolver un saldo, el sistema comprueba que la tarjeta solicitada pertenezca al usuario del token. Los intentos contra tarjetas ajenas se cuentan por token durante 60 s. Al llegar a 10, el token queda bloqueado temporalmente. Cada evento queda en la bitácora de auditoría.

Componentes: cliente/atacante simulado -> API de saldo -> capa de autorización -> estado de tarjetas -> bitácora de auditoría.

Requisitos implementados: propiedad token-tarjeta; rechazo 403; umbral 10; bloqueo temporal; auditoría con hora, usuario, tarjeta, acción y motivo.

Cómo medir: CSV `s2_security.csv` para porcentaje de rechazos y posición del bloqueo; `audit_security.csv` para reconstruir los eventos.

Experimento: 20 intentos con token-U001 contra tarjeta T200, que pertenece a U002.

Medida	Resultado local	Criterio
Consultas ajenas rechazadas	20/20 = 100 %	100 %
Saldos ajenos expuestos	0	0
Bloqueo	En intento 10	<= 5 s desde el intento 10

Resultado: el mecanismo de autorización y umbral funciona en la prueba local. La bitácora permite reconstruir la secuencia, que es un requisito explícito de medición de seguridad.

2. Táctica P1 - Controlar la demanda mediante priorización

Ajuste respecto a Parte 1: P1 seleccionaba caché para bajar latencia, pero la regla 2 de la Parte 2 prohíbe usar Caché como táctica de práctica. Se reemplaza por una táctica permitida ya identificada en la Parte 1: priorizar eventos. Las validaciones reciben prioridad alta y los resúmenes mensuales prioridad baja.

Escenario P1: 500 validaciones por segundo durante 10 min, con autenticación y control antifraude activos. La medida esperada es p95 <= 300 ms, p99 <= 600 ms y 0 solicitudes rechazadas por sobrecarga.

Cómo funciona: las solicitudes entran a una cola explícita. Las validaciones usan prioridad 0 y los resúmenes prioridad 10. Con prioridad habilitada, una validación no queda detrás de trabajo secundario cuando ambos compiten por recursos.

Componentes: generador de carga -> servidor de validación -> cola priorizada -> trabajadores -> estado de tarjetas. El paralelismo del servidor se usa para transportar la carga; la táctica de calidad es la prioridad, no "Introducir Concurrencia".

Requisitos implementados: 500 validaciones/s en la prueba; p95/p99; registro CSV por solicitud; configuración con y sin seguridad; comparación contra línea base.

Cómo medir: latencia del cliente por solicitud. Se calculan p95 y p99 sobre las validaciones, y el sobrecosto de seguridad como: (p95 con seguridad / p95 sin seguridad - 1) x 100.

Experimento local: 3 repeticiones de 2 s a 500 validaciones/s. Se usa la mediana de las tres repeticiones para reducir ruido de una máquina de laboratorio.

Configuración	p95 mediano (ms)	p99 mediano (ms)	Éxito
Sin seguridad	5.615	12.490	100 % aprox.
S2 + prioridad	5.661	7.219	100 %

Compromiso Seguridad vs Desempeño: sobrecosto de p95 = **0.82 %** en la muestra local, por debajo del límite de +20 % planteado en la Parte 1. Además, el p95 medido queda muy por debajo de 300 ms. Esta evidencia es exploratoria porque la corrida fue de 2 s, no de 10 min.

Archivos: `p1_nosec_rep_*.csv` y `p1_sec_rep_*.csv`.

3. Táctica D1 - Standby pasivo con replicación de estado + lease TTL

Ajuste respecto a Parte 1: D1 proponía réplica caliente/redudancia activa, pero la Parte 2 prohíbe Redundancia Activa. Se conserva el objetivo del escenario y se implementa un standby pasivo que mantiene una copia del estado, mientras un lease TTL renovado por el primario permite detectar su caída sin usar Ping/Echo.

Escenario D1: caída del nodo primario en hora pico. La respuesta esperada es detectar en <= 5 s, conmutar en <= 30 s, perder 0 transacciones confirmadas y mantener disponibilidad >= 99,9 % mensual.

Cómo funciona: el primario actualiza periódicamente un archivo de lease y replica el estado hacia el standby. Si el lease deja de renovarse, el monitor considera caído al primario y la operación puede continuar desde el standby pasivo.

Componentes: nodo primario -> estado/lease -> standby pasivo; cliente de validación -> nodo activo.

Requisitos implementados: dos procesos independientes; copia de estado; lease TTL de detección; verificación del estado desde standby después de la caída; CSV de experimento.

Cómo medir: timestamp de la caída y del reconocimiento del lease en `d1_failover.csv`; tiempo de respuesta del standby; conteo de solicitudes confirmadas perdidas.

Medida	Resultado local	Criterio
Detección	2.016 s	<= 5 s
Respuesta desde standby	HTTP 200	Disponible
Transacciones confirmadas perdidas	0	0

Resultado: la prueba local detectó la caída en aproximadamente 2.016 s y el standby respondió sin pérdidas confirmadas. La medición de conmutación completa debe repetirse con el escenario de 500 validaciones/s si se desea demostrar también el comportamiento en carga pico.

4. Verificación de escenarios

Escenario	Medida esperada (Parte 1)	Medida obtenida localmente	¿Cumple?
S2	100 % rechazadas; bloqueo <= 5 s; 0 saldos expuestos	100 % rechazadas; bloqueo en intento 10; 0 expuestos	Sí en muestra
P1	p95 <= 300 ms; p99 <= 600 ms; 0 rechazadas	p95 mediano 5.661 ms; p99 mediano 7.219 ms; 100 % éxito en 3 x 2 s	Sí en muestra; falta corrida 10 min
D1	Detección <= 5 s; conmutación <= 30 s; 0 pérdidas	detección 2.016 s; 0 pérdidas confirmadas	Sí en muestra

Interpretación: las tres tácticas tienen evidencia generada en archivos CSV. La principal medición pendiente para una entrega estricta es P1 a 500 validaciones/s durante 600 s, tal como exige el escenario de la Parte 1 y la Parte 2.

5. Entregables y ejecución

Repositorio: la carpeta contiene el código de los procesos, el generador de carga, las evidencias y este informe.

Un solo comando:

```
python run_practica.py
```

Para la prueba formal de P1:

```
python run_practica.py --full --rps 500
```

Evidencias incluidas: s2_security.csv, audit_security.csv, d1_failover.csv, p1_nosec_rep_*.csv y p1_sec_rep_*.csv, además de bitácoras de los procesos.

Recomendación para la entrega: ejecutar el comando formal en la máquina donde se presentará el práctico y reemplazar/añadir los CSV de 600 s al repositorio. El informe no debe presentar las pruebas de 2 s como si fueran las de 10 min.

Este documento toma como base la Parte 1 (variante V5), especialmente S2, P1, D1 y el compromiso Seguridad frente a Desempeño.